KPMG DSG Network Penetration Testing

KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud Test Report

Presented by the Digital Security Group Network Penetration Testing Team

Application Name	**KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud**
Line of Business	**Tax**
Penetration Test Type	**Pre-Production**
Report Type	**Initial (1.0)**
Tester	**Patel, Vishal**
Assessment Date	**05/26/2025 – 05/27/2025**
PPA	**892326**
RP	**892327**
PTI	**892330**

KPMG

This report is to assist with vulnerability remediation activities. This report does not carry an endorsement from the Network Penetration Testing team.

This report is for KPMG internal use only and its contents cannon be shared or distributed in any form with a third-party client or vendor without initiating the client inquiry process.

Table of Contents

Table of Contents **3**
Executive Summary **4**
Findings Summary 4
Recommendations 4
Engagement Details **5**
Pre-Testing Environment Setup and Scope 5
Limitations and Challenges 5
Technical Analysis and Findings **6**
Summary of Vulnerabilities 6
Appendices **7**
Digital Security Group Disclaimer Notice 7
Non-Production and Production Testing Advisory 7
Modifications during Testing Engagements 7
Severity Ratings 8
KPMG Network Penetration Testing Methodology Diagram 9

Executive Summary

The Digital Security Group engaged in a network penetration test of the KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud environment at the request of Tax. The test was conducted as a “white box” test from the perspective of an internal attacker with access to a virtual machine on the KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud environment. The main goals of the test were to evaluate the overall security posture associated with the KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud environment and to provide recommendations to remediate the vulnerabilities discovered. The test was conducted between 05/26/2025 and 05/27/2025.

Findings Summary

Throughout the duration of the test, the Network Penetration Testing team discovered **no vulnerabilities**. Severity ratings are an aggregate of several factors, such as likeliness of exploitation, potential impact to sensitive data, and level of access gained after exploitation. It is important to note that the severity ratings were assessed from the perspective of an attacker. There may be mitigating factors or other contextual insight that would lower the severity of a finding. Details on the vulnerability severity ratings can be found towards the end of the report under Severity Ratings.

The Technical Analysis and Findings section details each of the findings, the assets affected, and remediation steps.

Recommendations

KPMG requires a follow-on penetration test to verify all remediations were completed successfully and did not introduce new vulnerabilities. The Network Penetration Testing team also recommends performing at least annual penetration tests or when new changes are made on the network infrastructure.

Engagement Details

This section highlights some key issues and other context that should be noted when reviewing the findings. The context specific to this engagement may include things such as: temporary changes, general setup, as well as challenges faced by either team. It is recommended to understand that additional context does not always impact the severity of findings; but it may provide insights to any future omissions or limitations of the engagement and depth of some test cases.

Pre-Testing Environment Setup and Scope

The scope of the test consisted of networked assets in the KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud environment. The table below details the target assets provided to the Network Penetration Testing Team.

IP Address, CIDR, URL, FQDN.
VNET: 10.0.146.0/24
gmsgetb-app-subnet {10.0.146.64/27}
gmsgetb-gateway-subnet {10.0.146.96/27}
gmsgetb-mgmt-subnet {10.0.146.128/28}
gmsgetb-iaas-subnet {10.0.146.144/28}
gmsgetb-pep-subnet {10.0.146.160/27}
gmsgetb-sql-subnet {10.0.146.0/26}

Table 1 - Scoped Assets

Limitations and Challenges

The penetration test was conducted from a VM - usazwinqap8095 (10.0.146.135) accessed remotely from a KPMG laptop. From the workspace's application, an RDP connection was made to a clean installation of Microsoft Windows on a virtual machine. This configuration limited data transfers to pull results onto the KPMG laptop.

Technical Analysis and Findings

KPMG's Network Penetration Testing team conducted a penetration test against the KPMG Link Global Equity Tracker (GET) - US Client B - GMS Cloud environment to identify vulnerabilities that could lead to the exposure of sensitive data to an attacker. During the engagement, the penetration testing team executed the following phases of its testing methodology:

- **Discovery and Enumeration** – Performed live host discovery and identified listening ports. Services were then fingerprinted for version information or any other useful data.
- **Vulnerability Identification** – Used automated and manual tools, techniques, and procedures to discover potential vulnerabilities and attack vectors.
- **Exploitation** – Evaluated vulnerabilities and attack vectors through active exploitation attempts.
- **Post-Exploitation** – Follow-on attacks and data retrieval using data or footholds established in the exploitation phase.

The engagement was conducted as a "white box" test, meaning the team did not attempt to evade security mechanisms and had knowledge of the environment being tested. Testing was performed from a KPMG issued laptop. Initial access was granted through an Azure Portal VM, which was then used to RDP into a Windows Servers VM on the target network.

The following sections detail the vulnerabilities discovered during the penetration test. It is important to note that risk ratings provided by the Network Penetration Testing team are based on the perspective of an attacker that does not have full working knowledge of the target environment. Contextual elements, such as preemptive mitigations already implemented in the environment, may lower the risk rating assigned by the Network Penetration Testing team.

Summary of Vulnerabilities

No vulnerabilities were discovered during this penetration test.

Appendices

Digital Security Group Disclaimer Notice

Cybersecurity threats are continually changing, with new vulnerabilities discovered daily, and no application can ever be 100% secure no matter how much security testing is conducted. This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. Digital Security offers no warranties, representations or legal certifications concerning the applications or systems it tests.

All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. By using this reported information, you agree that Digital Security Group shall be held harmless in any event.

Non-Production and Production Testing Advisory

It is important for the customer to understand that the engagement testing in non-production environments such as UAT (User Acceptance Testing) or QC (Quality Control) represents what is found only in such environments. If there are inaccuracies, omissions, or changes made during or after the testing engagement; this may impact findings visibility and ultimately the accuracy of this report. It is equally important to note that UAT and QC environments should ultimately mimic the production environment. Digital Security Group testers, unless at the request of the customer do not typically perform testing within a production environment for general stability and safety concerns. If production testing is a requirement by the SRM (Security Relationship Manager), please create a separate PTI (Penetration Testing Intake) form for as such and notify the Digital Security Group testers.

Modifications during Testing Engagements

If the customer performs any modifications or changes to the testing environment during an engagement, this may adversely impact the accuracy of the report and findings. Customers should be prepared to freeze changes where possible. If not possible, please notify the Digital Security Group testers of the intended change, time of change, and to which assets it will affect.

Severity Ratings

The table below defines the vulnerability severity levels found in this report. The risk ratings are subjected to contextual factors related to the environment the vulnerabilities are found in.

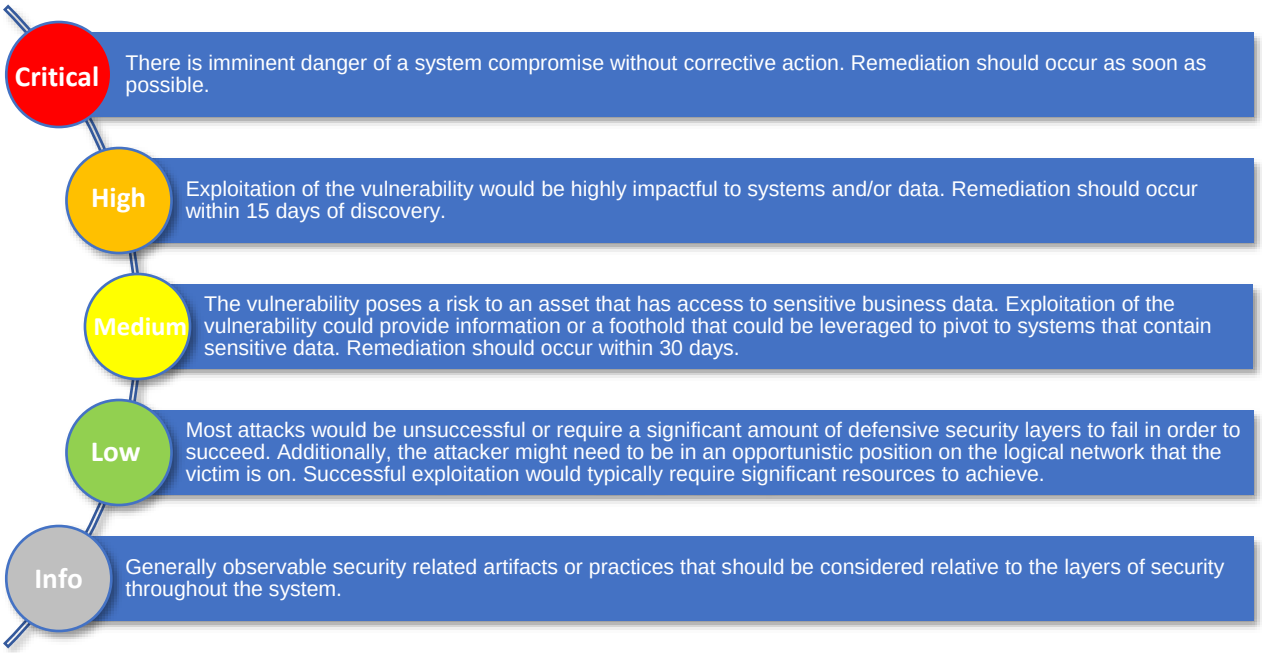

Figure 2 – Severity Ratings

KPMG Network Penetration Testing Methodology Diagram

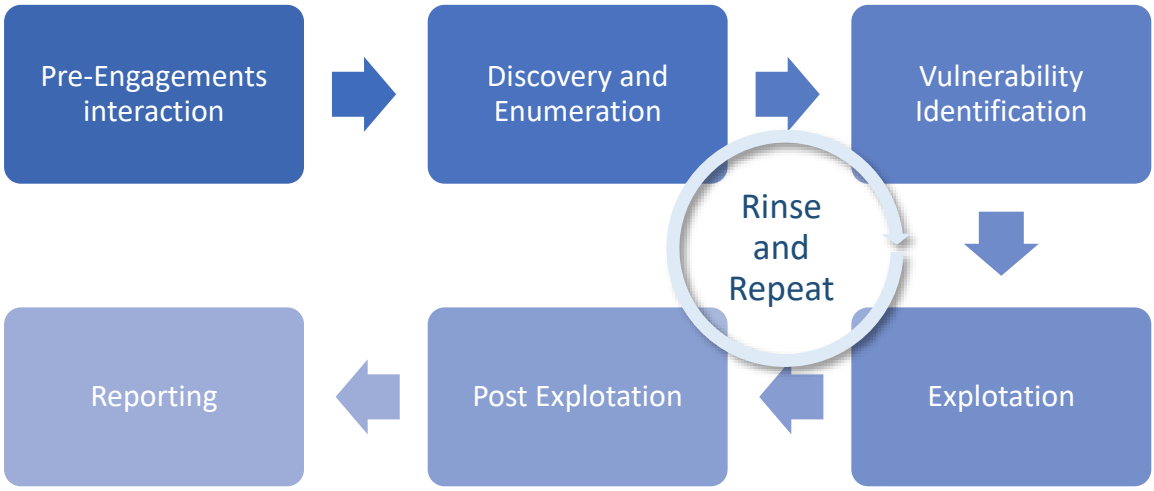

Figure 3 – Testing Methodology